

carland_auth — Flutter API guide (post QA)

carland_auth — Flutter API guide (NewUsers + Legacy)

Public base: <https://digital-innovation.agency/auth/server>

- Legacy (old app): /api/v1/users and /api/v1/otp
- NewUsers (new app): /api/v1/newUsers
- Header: Accept-Language: az | en | ru (SMS + error text)
- NewUsers PIN: Argon2id in pin_hash. Legacy password: BCrypt in password.
- Weak PIN (NewUsers only): 4 digits; reject all-same (1111) and sequences (1234, 4321).

A) NewUsers flow

User is NOT created on /auth. OTP verify may create the user. setPinCode returns status PIN_SET only — then call login. authToken is in JSON body (not Bearer), TTL ~6 min. purpose lives only in the JWT (server extracts + logs it).

Screen map (response.next)

- SEND_OTP — OTP screen → createAndSend
- PIN_CHECK — PIN login screen → login
- VERIFY_OTP — after createAndSend success; stay on OTP → verify
- SET_PIN — after verify; set-PIN screen → setPinCode

Happy paths

Register:

- 1) POST /auth { phoneNumber }
→ next=SEND_OTP, authToken, purpose=REGISTER
- 2) POST /otp/createAndSend { authToken } → next=VERIFY_OTP
- 3) POST /otp/verify { authToken, otp }
→ next=SET_PIN, pinSetupToken (not authToken)
- 4) PUT /setPinCode { pinSetupToken, pinCode } → { status: PIN_SET }
- 5) POST /login { phoneNumber, pinCode, deviceId, platform? }
→ accessToken + refreshToken

Existing user:

- 1) POST /auth { phoneNumber } → next=PIN_CHECK
- 2) POST /login { phoneNumber, pinCode, deviceId, platform? }

Forgot PIN:

- 1) POST /auth { phoneNumber, purpose:"RESET" } → next=SEND_OTP
(no user / no PIN → treated as REGISTER, no 404)
- 2) createAndSend → verify → setPinCode → login
RESET setPinCode revokes other devices' refresh sessions

A1) POST /api/v1/newUsers/auth

- Auth: none | Headers: Accept-Language

```
{
  "phoneNumber": "+994501234567",
  "purpose": "RESET" // optional
}
```

```
{
  "authToken": "<jwt ~6 min>",
  "next": "SEND_OTP" | "PIN_CHECK",
  "purpose": "REGISTER" | "RESET",
  "message": "..."
}
```

- pin_hash present → PIN_CHECK; else SEND_OTP
- 429 if phone >10/min or IP >30/min on /auth

A2) POST /api/v1/newUsers/otp/createAndSend

```
{
  "authToken": "<from /auth>"
}
```

- Success next: VERIFY_OTP
- 30s cooldown; 3 sends / 15 min → phone lock ~5 min (LOGIN_LOCKED + countdown)
- IP abuse → 24h lock, generic message, no countdown
- 401 AUTH_TOKEN_EXPIRED / INVALID_TOKEN
- OTP never in JSON; SMS only; Accept-Language az/en/ru

A3) POST /api/v1/newUsers/otp/verify

```
{
  "authToken": "<from /auth>",
  "otp": "123456"
}

{
  "pinSetupToken": "<jwt for setPinCode>",
  "next": "SET_PIN",
  "purpose": "REGISTER" | "RESET",
  "message": "..."
}
```

- 401 OTP_INCORRECT; 429 OTP_VERIFY_LOCKED (~300s); 400 OTP_EXPIRED

A4) PUT /api/v1/newUsers/setPinCode

- No query purpose — purpose is inside pinSetupToken JWT

```
{
  "pinSetupToken": "<from verify>",
  "pinCode": "2580"
}

{
  "status": "PIN_SET"
}
```

- 400 WEAK_PIN / PIN_LENGTH_ERROR

- Then MUST call login (no tokens from this step)

A5) POST /api/v1/newUsers/login

```
{
  "phoneNumber": "+994501234567",
  "pinCode": "2580",
  "deviceId": "<stable device id or FCM>",
  "platform": "ANDROID" | "IOS"
}
```

- deviceId required (alias deviceToken accepted)

- 401 PIN_INCORRECT / PIN_NOT_SET; 429 LOGIN_LOCKED (~300s)

- Each login APPENDS refresh_tokens row (history); not upsert

A6) Refresh (legacy endpoint)

POST /api/v1/users/refresh with Authorization: Bearer <refreshToken>

B) Error envelope

```
{
  "error": "LOGIN_LOCKED",
  "message": "localized text",
  "timeStamp": "...",
  "status": 429,
  "lockedUntil": "...",
  "remainingSeconds": 300,
  "retryAfter": 300
}
```

Named errors to handle

- AUTH_TOKEN_EXPIRED / INVALID_TOKEN → restart from phone
- OTP_EXPIRED / OTP_INCORRECT / OTP_VERIFY_LOCKED
- WEAK_PIN / PIN_LENGTH_ERROR
- PIN_INCORRECT / PIN_NOT_SET / LOGIN_LOCKED

C) Legacy — keep for old app

- Paths unchanged: login, register, otp/*, setPassword, updatePassword, refresh
- setPassword = free-form password (BCrypt) — NOT 4-digit PIN rules
- Legacy login may return 429 LOGIN_LOCKED after 3 wrong credentials
- Forgot password still: updatePassword → OTP → setPassword

D) Flutter checklist (NewUsers)

- Persist authToken for OTP steps; after verify use pinSetupToken
- Drive UI from next
- Do not send purpose query on setPinCode
- After PIN_SET always call login
- Handle 429 with countdown UI
- Never log OTP or PIN

Source of truth: carland_auth NewUsersController + legacy UserController.